INF384 · TEMAS AVANZADOS EN INGENIERÍA DE SOFTWARE 1 · 2026-2

Sesión 02

Introducción a DevSecOps

Modelo CALMS, estructura de equipos y anatomía de un pipeline de integración y despliegue

Capítulo 2 · 3 horas | RA2, RA3 | Prof. José Felipe del Castillo Salazar

PUCP

ARRANQUE

¿Quién despliega a producción donde trabajas?

Elige la opción más cercana a tu experiencia: curso, práctica o trabajo.

¿Quién tiene el permiso y el conocimiento para poner un cambio en producción?

1. Cualquiera del equipo
2. Solo el líder técnico
3. Un equipo de infraestructura
4. Una sola persona en toda la empresa
5. Nunca llegué a producción

ARRANQUE

¿Quién despliega a producción donde trabajas?

Elige la opción más cercana a tu experiencia: curso, práctica o trabajo.

¿Quién tiene el permiso y el conocimiento para poner un cambio en producción?

1. Cualquiera del equipo
2. Solo el líder técnico
3. Un equipo de infraestructura
4. Una sola persona en toda la empresa
5. Nunca llegué a producción

Si el conocimiento de despliegue vive en una sola persona, esa persona es una cola.

SESIÓN 2

Objetivo de la sesión y ruta

OBJETIVO

Evaluar el grado de adopción de prácticas DevSecOps de una organización usando el modelo CALMS, y explicar la estructura de un pipeline de integración y despliegue continuo.

Taller de Hoy

Hoy hay que emitir un juicio sobre una organización, con criterio y evidencia

1. **Qué es y qué no es**
   Definición operativa de DevSecOps.
2. **Modelo CALMS**
   Cultura, automatización, lean, medición y compartir. Las cinco dimensiones de la adopción.
3. **Estructura de equipos**
   Modelos organizacionales, sus condiciones de uso y el anti-patrón más frecuente.
4. **Anatomía del pipeline**
   Etapas de integración y despliegue continuo, y qué se valida en cada una.

Esta sesión aporta a los resultados de aprendizaje RA2 (diseñar pipelines de integración y despliegue continuo) y RA3 (integrar seguridad en el ciclo de vida).

CONTINUIDAD CON LA SESIÓN 1

De qué medimos a qué construimos

Lo que establecimos la semana pasada

- El tiempo se va en las colas, no en el trabajo.
- Las cuatro métricas DORA se reportan juntas o no significan nada.
- Velocidad y estabilidad se mueven como consecuencia una de la otra.

LA PREGUNTA DE HOY

Un diagnóstico dice dónde duele. No dice qué capacidades hay que construir para que deje de doler. Ese es el trabajo del modelo que vemos hoy.

DIAGNOSTICAR
Cap. 1
Completado

CONSTRUIR
Cap. 2–5
Estamos aquí

ASEGURAR
Cap. 6
El diferencial del curso

OPERAR Y ESCALAR
Cap. 7–9
Cierre del semestre

A

Qué es DevSecOps

Definición operativa, el muro entre áreas y por qué la seguridad va en el medio

CAPÍTULO 2.1

Qué es DevSecOps y qué no es

Conjunto de prácticas **culturales**, **organizativas** y **técnicas** que busca **acortar el ciclo** entre una idea y su llegada **segura** a producción, mediante **colaboración** entre desarrollo, operaciones y seguridad, y **automatización** del camino que recorre el cambio.

No es

- Un puesto de trabajo llamado "ingeniero DevOps".
- Un equipo que se sienta entre desarrollo y operaciones.
- Un conjunto de herramientas que se compra e instala.
- Sinónimo de "usar contenedores" o "estar en la nube".
- Una certificación.

Sí es

- Una forma de repartir responsabilidad sobre el flujo completo.
- Automatización del camino de un cambio hacia producción.
- Retroalimentación rápida en cada etapa del recorrido.
- Seguridad ejecutándose como parte del flujo, no al final.
- Una capacidad organizacional que se construye, no se compra.

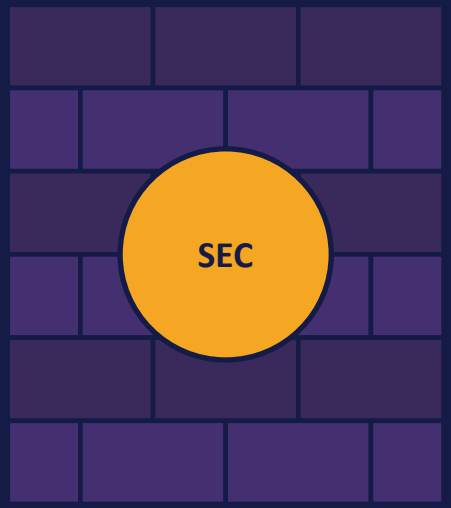
El puesto existe y varios de ustedes lo van a ocupar. Lo que no existe es que ese puesto, por sí solo, produzca DevSecOps en una organización.

LA METÁFORA DEL SILO

El problema original: el muro entre Dev y Ops

DEV

Su objetivo es el cambio.
Se le mide por entregar funcionalidad nueva.



OPS

Su objetivo es la estabilidad.
Se le mide por que nada se caiga.

Seguridad como puerta,
no como algo a ver en el camino

El muro no está hecho de mala voluntad: está hecho de objetivos contrapuestos. Mientras a un área se le mida por cambiar y a la otra por no caerse, el muro se reconstruye solo. Y la seguridad, que llega al final, termina siendo el guardián de una puerta que ya fue cruzada.

CAPÍTULO 2.1

Por qué "Sec" y por qué en el medio

1

El costo del defecto crece con el tiempo de detección

Una vulnerabilidad encontrada en el editor cuesta minutos. En revisión de seguridad previa al pase, cuesta un ciclo completo. En producción, cuesta incidente, notificación regulatoria y confianza.

2

La revisión al final no escala con la frecuencia de despliegue

Si el objetivo es desplegar varias veces al día, un control manual que toma tres días deja de ser un control: se convierte en la razón por la que se despliega poco.

3

La superficie de ataque ya no es solo el código propio

Dependencias de terceros, imágenes base de contenedores e infraestructura declarada en código. Nada de eso lo revisa una persona leyendo un pull request.

4

La evidencia de cumplimiento se produce sola o no se produce

En sectores regulados —banca, fintech, salud— la trazabilidad automática del pipeline es lo que hace auditable el proceso sin frenarlo.

CONTEXTO HISTÓRICO

De dónde viene todo esto

2001

Manifiesto Ágil

Se acorta el ciclo de desarrollo, pero el despliegue sigue siendo un evento separado y manual.

2009

Origen del término DevOps

Se plantea que desarrollo y operaciones compartan objetivos y herramientas en lugar de negociar entregas.

2013–2018

Consolidación de la evidencia

The Phoenix Project populariza la narrativa; Accelerate aporta la base empírica sobre desempeño de entrega.

2018–hoy

Incorporación de la seguridad

Marcos como el SSDF del NIST y la guía DevSecOps de OWASP formalizan la seguridad dentro del ciclo automatizado.

- SSDF: Marco de Desarrollo de Software Seguro
- NIST: Instituto Nacional de Estándares y Tecnología de los EE. UU

B

Modelo CALMS

Las cinco dimensiones con las que se diagnostica la adopción de una organización

Las cinco dimensiones

Marco de cinco dimensiones para evaluar qué tan lejos está una organización de operar bajo DevSecOps. Se usa como instrumento de diagnóstico organizacional, no como lista de verificación.

C

Culture

Responsabilidad compartida sobre el resultado

A

Automation

El camino a producción se ejecuta solo

L

Lean

Lotes pequeños y flujo continuo

M

Measurement

Decisiones sobre datos, no sobre opinión

S

Sharing

El conocimiento circula entre equipos

Las cinco dimensiones se sostienen entre sí: automatizar sin medir produce velocidad ciega, y medir sin cultura produce métricas que se manipulan.

CALMS · DIMENSIÓN 1

C — Culture

Responsabilidad compartida sobre el resultado en producción, y seguridad psicológica suficiente para que los problemas se reporten en lugar de esconderse.

Señales de que existe

- El equipo que construye es el que opera lo que construyó.
- Los incidentes se analizan sin buscar culpables.
- Seguridad participa en el diseño, no solo en la aprobación.
- Un desarrollador puede ver los registros de producción.
- Reportar un error propio no tiene costo de carrera.

Señales de que no existe

- El postmortem termina con el nombre de una persona.
- "Eso lo ve infraestructura" es una respuesta aceptable.
- Los accesos a producción son un símbolo de jerarquía.
- Se despliega los jueves porque el viernes nadie quiere estar de guardia.
- Los problemas se conocen pero no se escriben.

CALMS · DIMENSIÓN 2

A — Automation

El camino que recorre un cambio desde el repositorio hasta producción se ejecuta sin intervención manual, y es idéntico cada vez.

1

Repetibilidad

El mismo proceso produce el mismo resultado. Un despliegue manual bien hecho no es repetible: depende de quién lo hizo y de qué día era.

2

Trazabilidad

Cada ejecución deja registro de qué se construyó, con qué dependencias, quién lo aprobó y qué validaciones pasó. Esto es lo que hace auditable el proceso.

3

Velocidad de retroalimentación

La validación automática responde en minutos. Una revisión manual responde en días. La diferencia no es de eficiencia: cambia lo que el desarrollador puede aprender.

4

Liberación de criterio humano

Automatizar lo mecánico permite que las personas revisen lo que requiere juicio: diseño, riesgo, decisiones de arquitectura.

Cuidado con el atajo: automatizar un proceso malo produce un proceso malo ejecutándose más rápido y con menos supervisión.

CALMS · DIMENSIÓN 3

L — Lean

Optimizar el flujo completo en lugar de la eficiencia de cada área, trabajando en lotes pequeños y limitando el trabajo en curso.

LOTE GRANDE

Un despliegue mensual con 180 cambios. Si algo falla, hay 180 sospechosos y revertir significa perder el trabajo de un mes.

LOTE PEQUEÑO

Cuarenta despliegues al mes con 4 cambios cada uno. Si algo falla, el sospechoso es evidente y revertir cuesta minutos.

LÍMITE DE TRABAJO EN CURSO

Un equipo con 12 tareas abiertas simultáneas no entrega más rápido: entrega más tarde todas. La utilización alta genera colas, no producción.

LO CONTRAINTUITIVO

Reducir el tamaño del lote aumenta el número de despliegues, y aumentar el número de despliegues reduce el riesgo total. Es el mismo hallazgo de Accelerate que vimos la semana pasada, visto desde el lado del proceso.

CALMS · DIMENSIÓN 4

M — Measurement

Las decisiones sobre el proceso se toman con datos del propio flujo, y las métricas pertenecen al equipo que las produce.

1

Se miden las cuatro claves DORA, no la actividad individual

Líneas de código, tickets cerrados y horas registradas miden movimiento, no resultado.

2

La medición es automática y continua

Si producir el reporte cuesta un día de trabajo manual, se va a producir tarde, mal o nunca.

3

El equipo ve sus propios números

Una métrica que solo ve la gerencia sirve para evaluar. Una que ve el equipo sirve para mejorar.

4

Se mide también lo que no es velocidad

Cobertura de validaciones de seguridad, vulnerabilidades abiertas por severidad, deuda de dependencias.

CALMS · DIMENSIÓN 5

S — Sharing

El conocimiento, las herramientas y las soluciones circulan entre equipos en lugar de reinventarse o quedar atrapados en una persona.

1

Plantillas de pipeline reutilizables

Un equipo resuelve el pipeline seguro una vez y los demás lo heredan. Es el contenido del Capítulo 7 y del Laboratorio 6.

2

Postmortems públicos

El incidente de un equipo se convierte en aprendizaje de toda la organización, con acceso abierto y sin nombres.

3

Documentación viva

Documentación que vive junto al código y se actualiza con él, no un documento en una carpeta que nadie abrió en dos años.

4

Rotación y pares

Ninguna función crítica debe depender de una sola persona. Si alguien no puede tomar vacaciones, eso es un riesgo operativo.

Prueba práctica: si la persona que sabe desplegar se enferma, ¿la organización se detiene? Si la respuesta es sí, esta dimensión está en cero.

C

Estructura de equipos

Cuatro modelos organizacionales, sus condiciones de uso y el anti-patrón más frecuente

CAPÍTULO 2.3

Modelos de estructura de equipos

1 Silos separados

Dev, Ops y Seguridad como áreas independientes con traspasos formales entre ellas.

Punto de partida más común. No es un modelo objetivo.

2 Capacidad embebida

Cada equipo de producto incluye personas con conocimiento de operación y seguridad.

Funciona bien hasta cierta escala; luego duplica esfuerzo entre equipos.

3 Equipo de plataforma

Un equipo construye la plataforma y las plantillas que los equipos de producto consumen como autoservicio.

El modelo dominante a partir de cierto tamaño de organización.

4 Equipo de confiabilidad (SRE)

Un equipo especializado define objetivos de servicio y comparte la operación bajo condiciones acordadas.

Requiere madurez previa en medición y automatización.

Ningún modelo es correcto en abstracto: la pregunta correcta es qué restricción organizacional resuelve y cuál introduce.

ADVERTENCIA

Anti-patrón: el equipo DevOps como tercer silo

Cómo se ve

- Se crea un área nueva llamada DevOps entre desarrollo y operaciones.
- Todos los pipelines los escribe y los mantiene esa área.
- Los equipos de producto abren tickets para pedir cambios en su pipeline.
- El área DevOps se convierte en el nuevo cuello de botella.
- El lead time no mejora; ahora hay una cola más.

Qué hacer en su lugar

- El equipo especializado provee capacidades de autoservicio, no ejecuta trabajo ajeno.
- Los equipos de producto son dueños de su propio pipeline.
- Se entregan plantillas y valores por defecto seguros, no tickets atendidos.
- El éxito del equipo de plataforma se mide por la autonomía de los demás.

D

Anatomía del pipeline

Qué ocurre entre el commit y la producción, y qué se valida en cada etapa

CAPÍTULO 2.4

Anatomía de un pipeline: integración continua

Commit	Build	Pruebas unitarias	Calidad de código	Seguridad
El cambio llega al repositorio y dispara el pipeline automáticamente.	Se compila y se produce un artefacto único, versionado e inmutable.	Validación automática del comportamiento de las unidades de código.	Análisis estático: complejidad, duplicación, reglas del equipo.	Análisis de código y de dependencias antes de que exista un artefacto desplegable.

EL PRINCIPIO QUE LO ORDENA TODO

Falla rápido y barato. Lo que puede detectar un defecto en segundos va primero; lo que toma minutos va después. Ordenar el pipeline al revés desperdicia el tiempo de todos.

LA SALIDA DE ESTA ETAPA

Un artefacto versionado que pasó todas las validaciones. Ese mismo artefacto es el que se despliega a todos los ambientes: no se vuelve a construir por ambiente.

Se construye una vez y se despliega muchas veces. Lo que se probó es exactamente lo que se despliega.

CAPÍTULO 2.4

Anatomía de un pipeline: entrega y despliegue continuo

Publicación del artefacto	Provisión de infraestructura	Despliegue a preproducción	Aprobación	Despliegue a producción
El artefacto se almacena versionado en un repositorio, con su registro de origen.	El ambiente se declara como código y se crea de forma reproducible.	Se instala el artefacto y se ejecutan pruebas de integración y extremo a extremo.	Automática por criterios, o manual cuando la política de la organización lo exige.	Con estrategia de reversión definida y verificación posterior activa.

ENTREGA CONTINUA

Todo cambio que pasa el pipeline queda listo para desplegarse en cualquier momento. La decisión de desplegar es humana y de negocio.

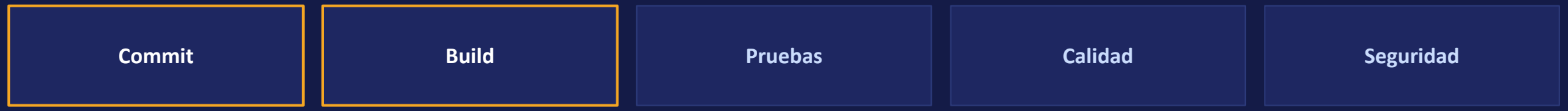
DESPLIEGUE CONTINUO

Todo cambio que pasa el pipeline llega a producción sin intervención humana. Exige un nivel de confianza en las validaciones que se construye, no se decreta.

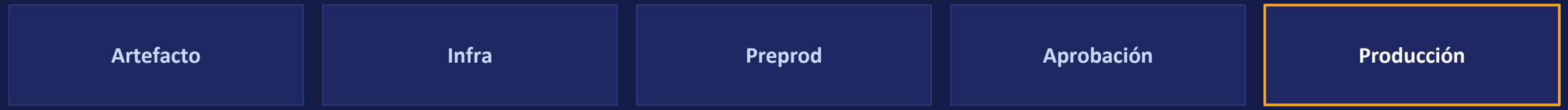
SÍNTESIS DEL CAPÍTULO

El recorrido completo, de commit a producción

INTEGRACIÓN CONTINUA · Capítulo 3



DESPLIEGUE CONTINUO · Capítulo 4



Borde ámbar: lo que se construyó en el Laboratorio 1.

ACTIVIDAD

Autodiagnóstico CALMS de sus casos

Consigna

- Vuelvan al caso que revisaron en la sesión 1 (lo pueden obtener de PAIDEIA).
- Califiquen cada dimensión CALMS de 1 a 5 y anoten la evidencia concreta del caso que sustenta cada calificación.
- Identifiquen la dimensión más débil.
- Propongan UNA intervención para esa dimensión, que se pueda ejecutar en tres meses.
- Escriban qué métrica DORA esperarían que se mueva si la intervención funciona.

Entregable: se sube al foro del aula virtual al terminar la sesión. Dos grupos exponen su dimensión más débil y su intervención.

Kahoot de cierre GRUPAL

DevSecOps Farmeando Aura



CIERRE SESIÓN 2

Cuatro cosas que se llevan

1

DevSecOps se construye, no se compra

Ninguna herramienta produce responsabilidad compartida. Si nada cambia en cómo se reparte el trabajo, no cambió nada.

2

El muro son los incentivos

Mientras a un área se le mida por cambiar y a la otra por no caerse, el silo se reconstruye solo.

3

Se construye una vez, se despliega muchas

Lo que se probó tiene que ser exactamente lo que llega a producción. Reconstruir por ambiente rompe esa garantía.